

Sécurité informatique

Les menaces, et comment ne pas se faire piéger

Nicholas Wolff · CC BY-SA 4.0

Sommaire

1

Les menaces

Cheval de Troie, virus, keylogger, rançongiciel, ver, backdoor

2

Les botnets

L’attaque par déni de service (DDoS)

3

Le phishing

Comment l’identifier ? Comment réagir ?

Les menaces

Cheval de Troie	**Virus**	**Keylogger**
Rançongiciel	**Ver**	**Backdoor**

Menace : rançongiciel (ransomware)

WannaCry



WannaCry : « Ooops, vos fichiers ont été chiffrés ! »

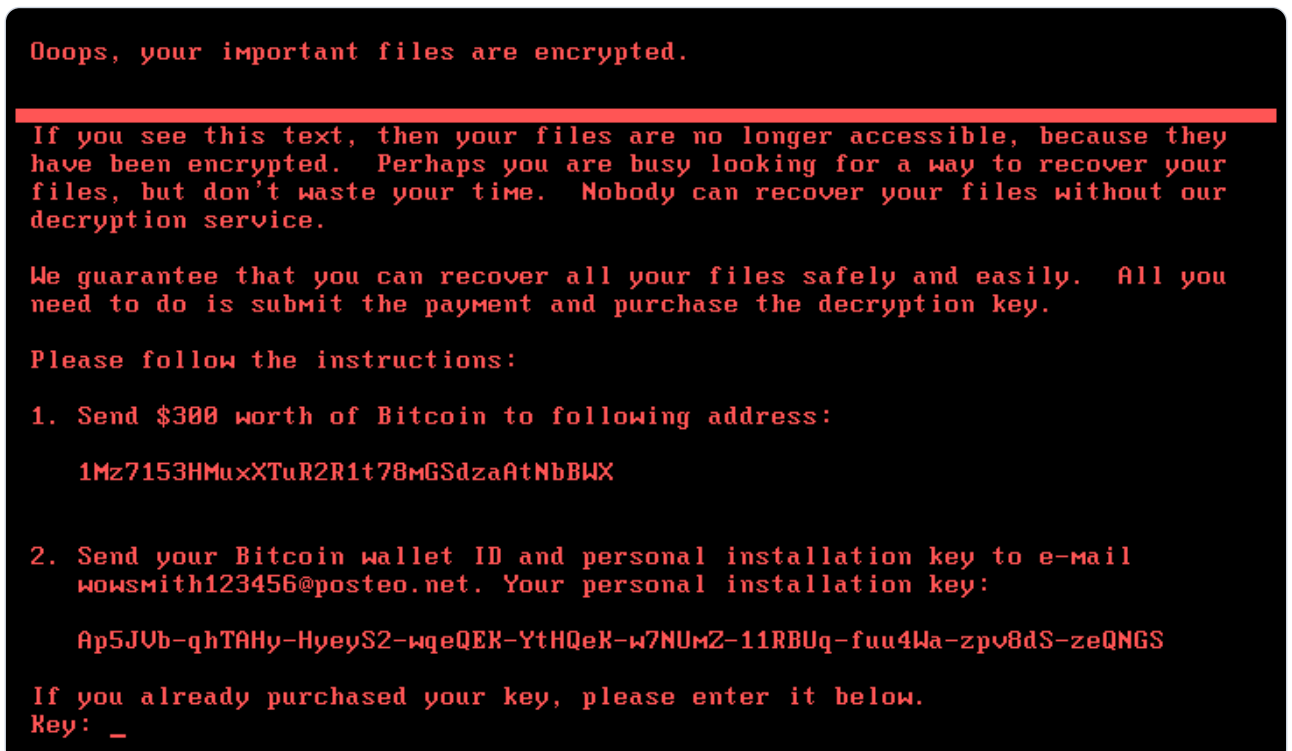
Que s'est-il passé avec mon ordinateur ?
Vos fichiers importants ont été chiffrés.
Beaucoup de vos documents, photos, vidéos, bases de données et autres fichiers ne sont plus accessibles car ils ont été chiffrés. Vous pourriez être occupé à chercher un moyen de les récupérer, mais ne perdez pas votre temps. Personne ne peut restaurer vos fichiers sans notre service de déchiffrement.

Comment payer ?
Le paiement est accepté uniquement en bitcoins. Pour plus d'informations, cliquez sur « About bitcoin ».
Veuillez vérifier le prix actuel du bitcoin et acheter des bitcoins. Pour plus d'informations, cliquez sur « How to buy bitcoins ». Et envoyez le montant exact à l'adresse indiquée dans la fenêtre.
Après le paiement, cliquez sur « Check Payment ». Si vous effectuez votre paiement, il sera vérifié et le bouton « Decrypt » sera activé.

Puis-je récupérer mes fichiers ?
Bien sûr. Nous garantissons que vous pouvez récupérer tous vos fichiers en toute sécurité et rapidement. Mais vous n'avez pas assez de temps.
Vous pouvez déchiffrer certains de vos fichiers gratuitement. Essayez maintenant en cliquant sur « Decrypt ». Mais si vous voulez déchiffrer tous vos fichiers, vous devez payer.
Vous avez seulement 3 jours pour effectuer le paiement. Après ce délai, le prix sera doublé. Aussi, si vous n'effectuez pas le paiement dans 7 jours, vous ne pourrez plus jamais récupérer vos fichiers. Nous allons alors supprimer la clé privée de votre ordinateur et vos fichiers seront perdus à jamais.

Menace : rançongiciel (wiper)

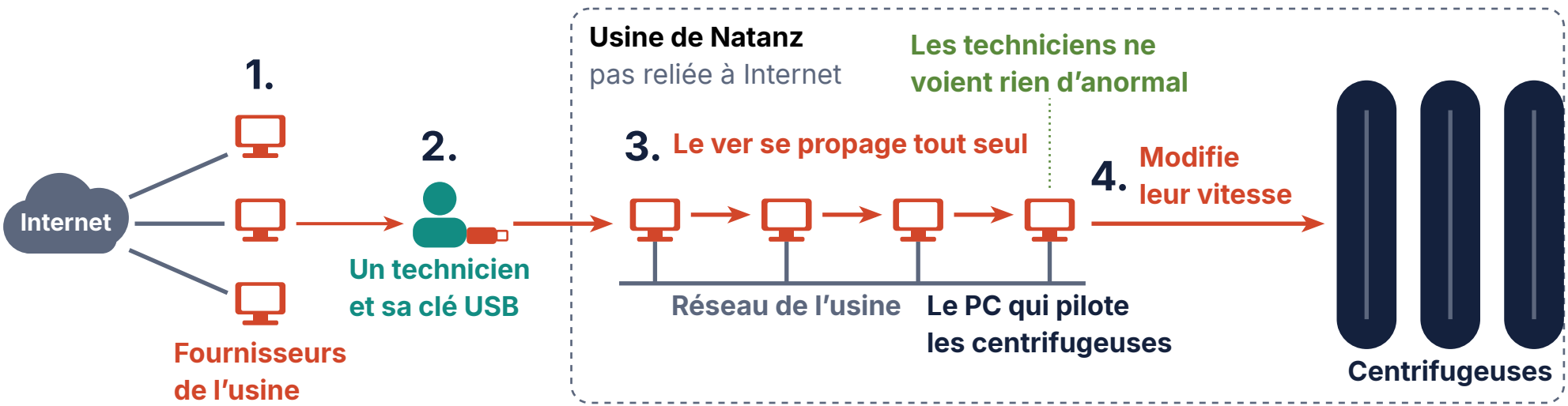
NotPetya



Menace : ver informatique

Un ver se propage tout seul, d'un ordinateur à l'autre par le réseau : contrairement à un virus, il n'a pas besoin qu'on ouvre un fichier infecté.

Stuxnet



Contexte : découvert en 2010, Stuxnet est attribué aux États-Unis et à Israël, qui voulaient empêcher l'Iran de fabriquer la bombe atomique.

Stuxnet, couche par couche

Une vraie attaque combine plusieurs menaces.

Un raccourci piégé, sur la clé USB
Il se lance dès qu'on ouvre la clé : pas besoin de cliquer dessus.

Le ver
Il se copie d'un ordinateur à l'autre, et se fait passer pour un logiciel de confiance.

Le piège dans le logiciel Siemens
Il attend de tomber sur le PC qui pilote les centrifugeuses.

La charge utile
Elle modifie la vitesse des centrifugeuses, et montre aux techniciens des valeurs normales.

Comme des poupées russes : chaque couche transporte la suivante, jusqu'à la charge utile, qui fait les dégâts.

Sommaire

1
Les menaces
Cheval de Troie, virus, keylogger, rançongiciel, ver, backdoor

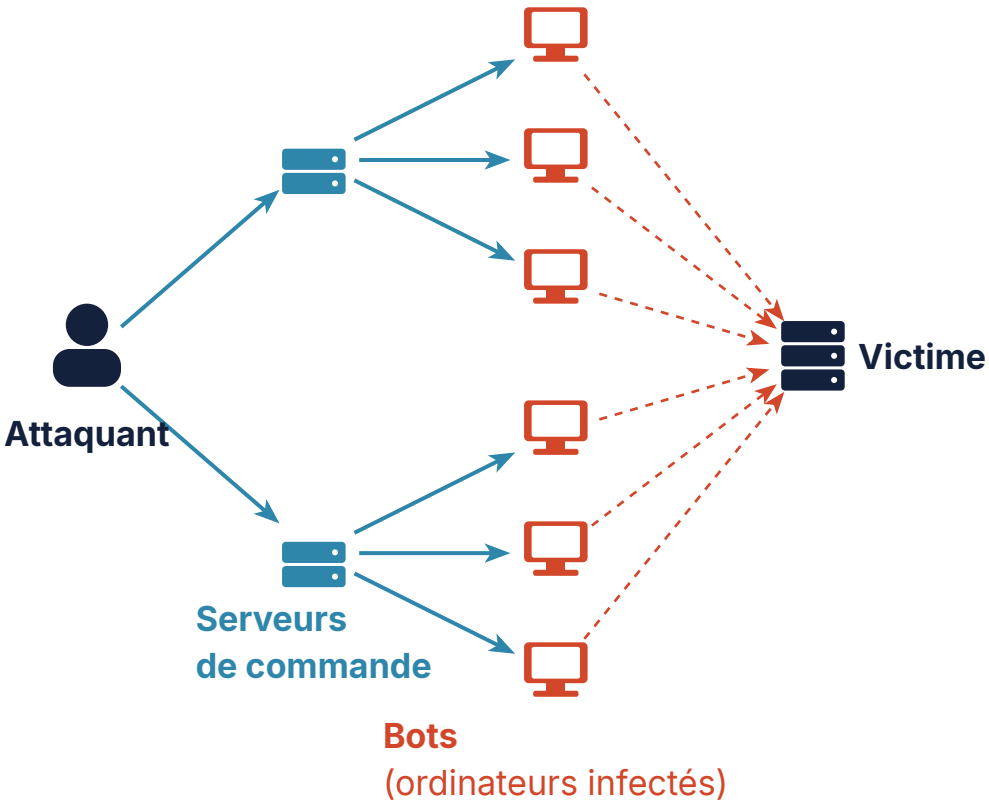
2
Les botnets
L'attaque par déni de service (DDoS)

3
Le phishing
Comment l'identifier ? Comment réagir ?

Botnet

Un botnet est un groupe d'ordinateurs ou d'appareils sous le contrôle d'un attaquant, utilisé pour mener des activités malveillantes contre une victime ciblée.

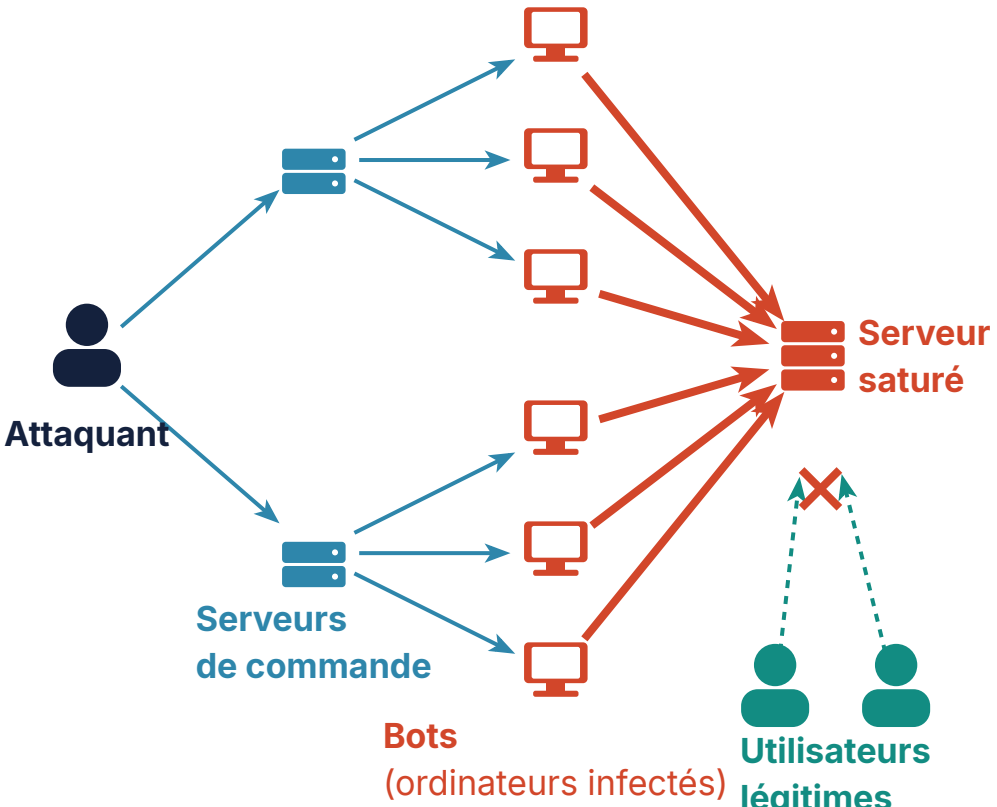
Le terme « botnet » combine les mots « robot » et « réseau » (*network* en anglais).



Attaque distribuée par déni de service (DDoS)

Une attaque par déni de service distribué (DDoS, pour *Distributed Denial of Service* en anglais) vise à rendre un serveur inaccessible, en lui envoyant de multiples requêtes jusqu'à le saturer, afin de provoquer une panne ou un fonctionnement fortement dégradé.

- **Distribuée**, parce que l'attaque vient de nombreuses machines, de partout.
- **Déni de service**, parce que les utilisateurs légitimes ne peuvent plus utiliser le service.



Sommaire

1
Les menaces
Cheval de Troie, virus, keylogger, rançongiciel, ver, backdoor

2
Les botnets
L’attaque par déni de service (DDoS)

3
Le phishing
Comment l’identifier ? Comment réagir ?

Phishing / hameçonnage

L’hameçonnage, ou phishing, est une technique utilisée par des fraudeurs pour obtenir des renseignements personnels, afin d’usurper l’identité de la victime, ou pour lui faire installer un logiciel malveillant.

Pour obtenir les renseignements, l’attaquant copie souvent un site à l’identique : la victime croit être sur le site officiel, et y tape son mot de passe. Pour le logiciel malveillant, il envoie une pièce jointe ou un lien à télécharger.

Phishing ciblé ou de masse

Le spear phishing (harponnage)

Un message préparé pour une personne précise, souvent dans une entreprise. L'attaquant se renseigne d'abord sur elle.

Le but : un gros virement, ou un accès au réseau de l'entreprise.

Le phishing de masse

Le même message, envoyé à des milliers de personnes. Le but :

- voler de l'argent : accès à la banque en ligne, numéro de carte ;
- voler des comptes de réseaux sociaux : leurs profils contiennent de nombreux éléments privés, qui permettent ensuite de piéger la victime et ses amis ;
- faire installer un logiciel malveillant, par une pièce jointe ou un lien.

Harponnage : l’arnaque au président

L’arnaque au président, appelée aussi FOVI (faux ordres de virement), vise les entreprises de toute taille. Les escrocs se font passer pour le dirigeant de l’entreprise et demandent un virement bancaire, en prétextant une opération financière urgente et confidentielle.

Arup (Hong Kong, janvier 2024)
bureau d’ingénieurs, celui de l’Opéra de Sydney

Le service financier reçoit en visioconférence le directeur financier et des collègues : ce sont tous des deepfakes. Une perte de 25 millions de dollars.

Une entreprise de Schwyz (janvier 2026)
son propriétaire, au téléphone

La voix d’un partenaire d’affaires connu, imitée par une IA : plusieurs millions de francs partent vers un compte en Asie.

Harponnage : une attaque racontée

Activité · 6 min

Regarder la vidéo : youtube.com/watch?v=ZLAT2pggbNQ (4 minutes)

1. Reconstruire l'historique de cette attaque.
2. Identifier 3 ou 4 techniques utilisées pour rendre l'e-mail crédible et pousser les gens à cliquer sur la pièce jointe.
3. Quel impact sur l'entreprise ? Quelle responsabilité pour la hackeuse ?

Harponnage : mise en commun

1. L’historique

1. Elle se renseigne sur les personnes clés de l’entreprise, leur famille, leurs amis.
2. Elle envoie un e-mail qui semble venir du patron, avec une pièce jointe piégée.
3. Le rançongiciel bloque tout. L’entreprise doit publier ses résultats dans 2 heures : elle paie la rançon.
4. C’était une diversion : pendant ce temps, les données des clients et les comptes de l’entreprise sont volés, puis publiés.

2. Les techniques

- L’e-mail semble venir du patron : on obéit à l’autorité.
- La signature de l’entreprise, le ton du patron : tout a l’air familier.
- Un message préparé pour ces personnes-là, pas du spam.
- Des informations obtenues auprès du service des ventes, toujours pressé de répondre.

3. Impact et responsabilité

- Les données des clients sont publiées, l’action perd 14 %, le patron démissionne.
- La hackeuse se dédouane : « je n’ai fait que récupérer les fichiers ». Mais sans elle, pas d’attaque, et s’introduire dans un système informatique est puni par la loi.

Phishing : faux site dleci.ch

dieci.ch ≠ dleci.ch

- dieci.ch : « Les cybercriminels ont copié dieci.ch à l'identique »
- La copie de l'article, en PDF

Exemple de phishing

De : Gendarmerie Vaudoise <da.tombez@bluewin.ch>
Date : jeudi, 18 septembre 2025 à 23:38
À : Gendarmerie Canton de Vaud <cantondevaudg@gmail.com>
Objet : Re: Flagrant délit

Bonsoir,

Une enquête menée par nos services a mis en lumière vos agissements sur internet. En effet, votre adresse mail est inscrite sur un site pornographique frauduleux contenant des mineurs. Puisque cet acte est interdit et sévèrement punit par nos lois, nous vous incitons à immédiatement vous justifier en cliquant sur: https://cybercrimegendarmerie-infos/justificationsvd.ch sous peine de poursuites pénales.

mailto:infosgendarmeriecantondevaud@googlemail.com

Adj. Daniel Tombez
Gendarmerie Cantonale Vaudoise

Comment identifier un message de phishing ?

Un message de phishing peut arriver par e-mail, par SMS, par WhatsApp ou sur les réseaux sociaux. Les mêmes vérifications s'appliquent partout.

1.
Le message
Que me demande-t-on, et sur quel ton ?

2.
L'expéditeur
Qui a vraiment envoyé ce message ?

3.
Les liens
Où m'emmènent-ils réellement ?

4.
Les pièces jointes
Puis-je les ouvrir sans risque ?

Vérifier le contenu du message

Plusieurs signaux doivent alerter :

- **L'urgence ou la menace :** « Votre compte sera supprimé dans 24 h », « Dernier avertissement »
- **Une demande d'informations personnelles :** mot de passe, code reçu par SMS, numéro de carte
- **Une offre trop belle :** carte cadeau, gain à un concours auquel on n'a pas participé
- **Une formulation étrange :** fautes, traduction automatique, salutation impersonnelle (« Cher utilisateur »)
- **Un message inattendu :** un document « partagé » par quelqu'un qui n'envoie jamais rien

Le bon réflexe : si le message presse d'agir, prendre justement le temps de vérifier.

Vérifier l'expéditeur

Le nom affiché (« Secrétariat », « Service informatique ») peut être choisi librement par n'importe qui. Ce qui compte, c'est l'adresse complète, et surtout ce qui se trouve après le @. Pour le gymnase, le domaine attendu est **`@eduvaud.ch`**.

Nom affiché	Adresse
Secrétariat du gymnase	`secretariat.gdb@`**`gmail.com`**
Microsoft 365 Eduvaud	`no-reply@eduvaud.ch.`**`verif-compte.net`**

Attention : un compte @eduvaud.ch piraté peut aussi envoyer du phishing. Vérifier aussi le contenu et les liens.

Le bon réflexe : cliquer sur le nom de l'expéditeur (ou le survoler avec la souris) pour afficher son adresse complète.

Vérifier les liens

Le texte d'un lien peut afficher une adresse, et mener vers une tout autre. Seule l'adresse réelle compte.

Affiché : `eduvaud.sharepoint.com/document`
Réel : `https://eduvaud-sharepoint.com.`**`login-verify.io`**`/`

Affiché : Se connecter à Moodle

Réel : `https://`**`moodle-gymnasedebeaulieu.ch`**`/login`

Le bon réflexe : survoler le lien sans cliquer (sur téléphone : appui long), et lire l'adresse qui s'affiche.

Lire une adresse web

Repérer le premier « / » après « https:// ». Juste avant, lire de droite à gauche : les deux derniers blocs forment le vrai domaine.

`https://moodle.`**`gymnasedebeaulieu.ch`**`/course/`
→ vrai domaine : **`gymnasedebeaulieu.ch`**

`https://eduvaud.`**`sharepoint.com`**`/sites/`
→ vrai domaine : **`sharepoint.com`**, l'espace eduvaud

`https://moodle.gymnasedebeaulieu.ch.`**`connexion-eleves.net`**`/`
→ vrai domaine : **`connexion-eleves.net`**

Les adresses de confiance pour les cours sont donc `moodle.gymnasedebeaulieu.ch` et `eduvaud.sharepoint.com`.

Se méfier des pièces jointes

Une pièce jointe peut contenir un logiciel malveillant, qui vole les mots de passe ou chiffre les fichiers. L'ouvrir peut suffire.

- N'ouvrir une pièce jointe que si l'expéditeur est fiable et le message cohérent.
- Se méfier des fichiers `.zip`, `.html`, `.exe`, et des documents Office qui demandent d'« activer les macros ».
- Une facture ou un colis qu'on n'attendait pas ? Ne pas l'ouvrir.

Le bon réflexe : en cas de doute, demander à l'expéditeur par un autre moyen (en personne, par téléphone) s'il a bien envoyé ce fichier.

Les bons réflexes

- **Le message :** s'il presse d'agir, prendre justement le temps de vérifier.
- **L'expéditeur :** afficher son adresse complète, et lire ce qui suit le @.
- **Les liens :** les survoler sans cliquer (sur téléphone : appui long), et lire l'adresse réelle.
- **L'adresse web :** repérer le premier « / » après « https:// » ; les deux blocs juste avant forment le vrai domaine.
- **Les pièces jointes :** en cas de doute, demander à l'expéditeur par un autre moyen s'il a bien envoyé ce fichier.

Phishing ou pas ? Exemple 1

De : DGNSI <info.dgnsi@onlineadmin.ch>
Envoyé : mardi, 31 août 2021 12:14
À : [redacted]
Objet : Mise à jour de l'accès à distance SSL VPN VD via Pulse Secure

Bonjour,

Une mise à jour de sécurité de votre accès à distance VPN SSL par le client applicatif Pulse Secure, est disponible dès à présent.
Afin d'être protégé au mieux, vous devez faire cette mise à jour de sécurité rapidement en suivant la procédure qui suit.

1. Utilisez le lien suivant afin d'effectuer la mise à jour : « Cliquez ici pour la mise à jour »
2. Connectez-vous sur ce portail dédié.
3. Suivez la démarche décrite jusqu'à la fin de la mise à jour par la version Pulse Secure Desktop Client 9.1R1.
4. Reconnectez-vous ensuite à l'aide du profil vous correspondant.
5. La procédure est terminée.
6. En cas de problème durant la mise à jour, merci de contacter votre Helpdesk.

Installer la mise à jour SSL VPN VD

Pour plus d'informations, veuillez-vous référer à notre page web: « Les accès à distance au réseau de l'Administration cantonale ».

canton de vaud

Direction générale du numérique et des systèmes d'information
ENSEMBLE POUR UNE SOCIÉTÉ NUMÉRIQUE RESPONSABLE

Phishing ou pas ? Exemple 2

Enregistrement d'un nouvel appareil

N

noreply@vd.ch <noreply@vd.ch>

samedi, 25 septembre 2021 à 22:16

À : [redacted]

Bonjour [redacted]

Vous avez récemment associé un nouvel appareil à votre compte pour vos connexions en authentification forte sur le portail IAM.

Date : Le 25.09.2021 à 22:16:49
Appareil : Android - Chrome 93
Localisation : [redacted]

Pour accéder à la gestion des appareils associés à votre compte ou si vous souhaitez désactiver les notifications, veuillez cliquer sur le lien ci-dessous, rubrique 'authentification forte' :
https://www.portail.vd.ch/iam/selfservice

Si vous n'êtes pas à l'origine de cette action, veuillez contacter le helpdesk : helpdesk@vd.ch ou (021 31)6 26 60.

Si vous avez besoin d'aide, vous pouvez consulter la page suivante : https://www.vd.ch/iam-aide/

Meilleures salutations.

canton de vaud

Support IAM

Direction générale du numérique et des systèmes d'information (DGNSI)
Avenue de Longemalle 1, CH-1020 Renens
www.vd.ch/iam-aide

Phishing ou pas ? Exemple 3

Notification!

S

support@so2shop.com <support@so2shop.com>

dimanche, 28 août 2022 à 02:42

À : GYBEA HelpDesk

Salut!
Malheureusement, j'ai une mauvaise nouvelle pour vous, il y a quelques mois, j'ai eu accès à l'appareil que vous utilisez pour naviguer sur Internet. Depuis lors, je surveille votre activité sur Internet et, en tant que visiteur adulte régulier du site Web, je peux confirmer que cela relève de votre responsabilité.
Pour votre commodité, les sites Web que vous avez visités m'ont donné accès à vos données.
J'ai téléchargé un Njrat sur un pilote qui met à jour sa signature plusieurs fois par jour afin que l'antivirus ne puisse pas le détecter. J'ai également accès à votre caméra et à votre microphone, et j'ai sauvegardé toutes vos données, y compris les photos, les réseaux sociaux, le chat et les contacts. Récemment, j'ai eu une idée incroyable de tourner une vidéo dont vous faites partie pendant que la vidéo est en cours de lecture sur un autre écran en même temps. Soyez assuré que je peux envoyer cette vidéo à tous vos contacts en quelques clics, et je suppose que vous voulez éviter ce scénario, donc ma suggestion est de transférer l'équivalent de 1450 EUR sur mon portefeuille bitcoin et je l'oublierai . Je supprime également définitivement toutes les données et vidéos, ce qui à mon avis est un prix relativement modeste pour mon travail. Si vous achetez des bitcoins via un moteur de recherche comme Google ou Bing, vous constaterez que ce n'est pas trop difficile. Mon portefeuille bitcoin (BTC) : 1PTsGt1Tk8veNJpXTq6DC9R75ABfQ4wZjb
Vous avez 48 heures pour répondre et vous devez également être conscient de ce qui suit : Cela n'a aucun sens de me répondre - l'adresse a été générée automatiquement, il est inutile de se plaindre car la lettre et mon portefeuille bitcoin ne peuvent pas. Tout allait bien organisé. Si jamais je découvre que vous avez parlé de cette lettre à quelqu'un, la vidéo sera immédiatement partagée et vos contacts la recevront en premier. Ensuite la vidéo sera publiée sur le web ! PS Le temps commence dès que vous ouvrez cette lettre. (Ce programme a une minuterie intégrée).
Bonne chance et paix! C'était juste de la malchance, la prochaine fois sois prudent.

Comment réagir à un message de phishing ?

- Ne surtout pas ouvrir les pièces jointes
- Ne pas cliquer sur les liens
- Ne pas répondre
- Sur une messagerie scolaire ou professionnelle : transférer le message au support informatique, pour qu'il puisse réagir, puis le supprimer et vider la corbeille
- Ailleurs (SMS, WhatsApp, réseaux sociaux) : bloquer l'expéditeur et supprimer le message
- Si on a déjà cliqué ou donné son mot de passe : le changer tout de suite, et prévenir le support informatique

Sources

Les menaces et le phishing

Wikipédia — WannaCry
fr.wikipedia.org

Wikipédia — NotPetya
fr.wikipedia.org

Wikipédia — Stuxnet
fr.wikipedia.org

Dieci — « Les cybercriminels ont copié dieci.ch à l'identique »
dieci.ch

L'arnaque au président

Fortune — Arup, 25 millions de dollars
fortune.com

SRF — une entreprise schwytzoise perd des millions
srf.ch

Fortune — Ferrari déjoue un deepfake de son PDG
fortune.com

OFCS — « Virement urgent » (chiffres 2025)
bacs.admin.ch

Images

Giovanni Domenico Tiepolo — *La Procession du cheval de Troie* (vers 1760)

Kaspersky (Securelist) — l'écran de WannaCry